Computer Security & Forensics · 2023

CSE 461 | Session Not printed | 2023 final

Model study answers. Every listed option is addressed. Question titles are paraphrased; exact wording and original diagrams are in the source pages appended to this pack.

The printed Security header says 2023 but does not show a session. It is not relabelled as session 2019-20. All listed options are addressed. Educational descriptions of attacks are paired with defensive context; no live system is targeted.

Quick revision

Birthday collision P=1−product(i=0..n−1)(1−i/N).

AES state uses column-major byte order; MixColumns uses GF(2^8), not ordinary integer addition.

RSA n=pq; phi=(p−1)(q−1); ed≡1 mod phi; C=M^e mod n.

ElGamal y=g^x mod p; c1=g^k; c2=M y^k; M=c2/(c1^x), modulo p.

2-byte salt has 2^16=65,536 possible values; known-salt targeting differs from all-salt precomputation.

1(a) | Confidentiality and four controls

Confidentiality prevents information being disclosed to unauthorized parties. Four supporting controls are encryption, authentication, access-control/authorization rules and physical protection. Example: encrypt a student database, require verified user identities, restrict records by role and secure the server location. Authentication identifies the user; authorization decides what that user can read.

Revision answer: Prevent unauthorized disclosure using encryption, authentication, authorization and physical controls.

1(b) | Biometrics and four candidates

Biometric authentication uses measurable physical or behavioral characteristics to help recognize a person. Candidates include fingerprint, iris pattern, facial features and voice characteristics. Enrollment stores a protected reference/template and later samples are compared against it. Performance depends on false acceptance/rejection and resistance to spoofing; a biometric is not a secret that can simply be changed like a password.

Revision answer: Fingerprint, iris, face and voice are biometric candidates.

1(c) | Possible attack on one-time-pad encryption

A correctly used OTP with a uniformly random secret key as long as the message, used exactly once, has perfect secrecy against ciphertext-only recovery. There is no generic brute-force method that uniquely identifies the true plaintext without additional information.

A reused pad is vulnerable: C1 xor C2=P1 xor P2 exposes relations between messages. OTP also lacks integrity: a ciphertext bit flip causes the corresponding plaintext bit flip, so known-format messages can be modified without learning the key. Key theft or nonrandom pads break the assumptions.

Revision answer: Correct OTP resists plaintext recovery, but pad reuse, key compromise and unauthenticated modification are threats.

1(d) | Worm/malware lifecycle stages

A common classroom malware lifecycle is dormant (optional waiting), propagation (replication/spread), triggering (a condition activates the payload) and execution (the payload performs its action). Worm propagation includes discovering reachable targets and spreading through vulnerabilities or other channels. "Development steps" could instead mean a course-specific construction model; the uploaded question does not define one, so this answer states the lifecycle interpretation. Defensive controls include patching, isolation, least privilege and monitoring at each stage.

Revision answer: Dormant → propagation → triggering → execution, under the lifecycle interpretation.

1(e) | Why a switch is usually safer than a hub

A hub repeats incoming signals to other ports, so any attached device can observe traffic on that shared segment. A switch learns MAC locations and normally forwards known unicast frames only to the relevant port, reducing casual interception. This is an improvement, not guaranteed confidentiality: broadcasts and unknown unicasts can be flooded, and ARP spoofing or configuration errors still threaten traffic. Use encryption and switch protections too.

Revision answer: Switches reduce unnecessary unicast exposure; hubs repeat traffic to all ports.

1(f) | Preventing ARP spoofing

Enable Dynamic ARP Inspection using trusted DHCP-snooping bindings so inconsistent ARP claims are rejected. For small fixed environments, carefully maintained static ARP bindings can protect critical peers, though they are difficult to scale. Restrict untrusted access ports and segment networks. TLS or VPN encryption reduces what an interceptor can read, but does not itself validate ARP messages. The question's "two reasons" is interpreted as two preventive measures.

Revision answer: Use Dynamic ARP Inspection/DHCP snooping and appropriate static bindings or port controls.

1(g) | Symmetric keys in server-only communication

If N client users communicate only with one additional central server, give each client one unique shared key with the server. That requires N different keys, not $N(N-1)/2$, because client-to-client encrypted links are not required. If N counts all nodes including the server, the number would be $N-1$; state the interpretation.

Revision answer: N client users plus a server require N distinct client-server shared keys.

1(h) | Second-preimage versus collision resistance

Second-preimage resistance: given one particular message m, it should be infeasible to find a different m' with $H(m')=H(m)$. Collision resistance: it should be infeasible to find any distinct pair m,m' with equal hashes; neither is fixed in advance. For an ideal n-bit hash, generic work is about 2^n for second preimages and $2^{(n/2)}$ for collisions, subject to the usual idealized assumptions.

Revision answer: Second preimage fixes one message; collision search chooses both messages.

2(a) | Ten security principles

1. Economy of mechanism: keep the trusted design small and understandable. 2. Fail-safe defaults: deny access unless it is explicitly granted. 3. Complete mediation: check authorization for every relevant access. 4. Open design: rely on protected keys, not secrecy of the design. 5. Separation of privilege: require independent conditions for sensitive access.

6. Least privilege: grant only the permissions needed. 7. Least common mechanism: minimize shared mechanisms that can leak or couple users. 8. Psychological acceptability: make secure use understandable and practical. 9. Work factor: ensure bypass costs are sufficiently high relative to attacker resources. 10. Compromise recording: make successful or attempted misuse detectable and attributable through protected audit records.

This is the classic eight design principles plus the two additional considerations often taught with them; the paper itself does not enumerate its intended list.

Revision answer: Small design, deny by default, check access, open design, separate privilege, least privilege, limit sharing, usability, work factor and auditability.

2(b) | Confusion and diffusion in AES

Confusion makes the relationship between key and ciphertext complex; AES SubBytes provides nonlinear substitution and supports confusion. Diffusion spreads each input's influence across multiple output positions; ShiftRows permutes byte positions and MixColumns combines bytes, together spreading differences across rounds. AddRoundKey combines state and round-key bytes by XOR; it injects key dependence but alone is linear and does not supply all the cipher's confusion.

Revision answer: SubBytes supports confusion; ShiftRows plus MixColumns support diffusion.

2(c) | Computer forensics and forensic paradigm

Computer forensics systematically preserves and examines digital data to establish defensible findings about events. A practical paradigm is collection/preservation, examination, analysis and reporting. Collect with authorization and maintain chain of custody; acquire appropriately verified copies, examining copies when possible. Extract relevant artifacts; correlate them and assess alternative explanations; then report methods, evidence, limitations and conclusions. Record timestamps, tool actions and hashes so others can assess integrity and reproduce the reasoning.

Revision answer: Preserve/collect → examine → analyze → report, with integrity and chain of custody.

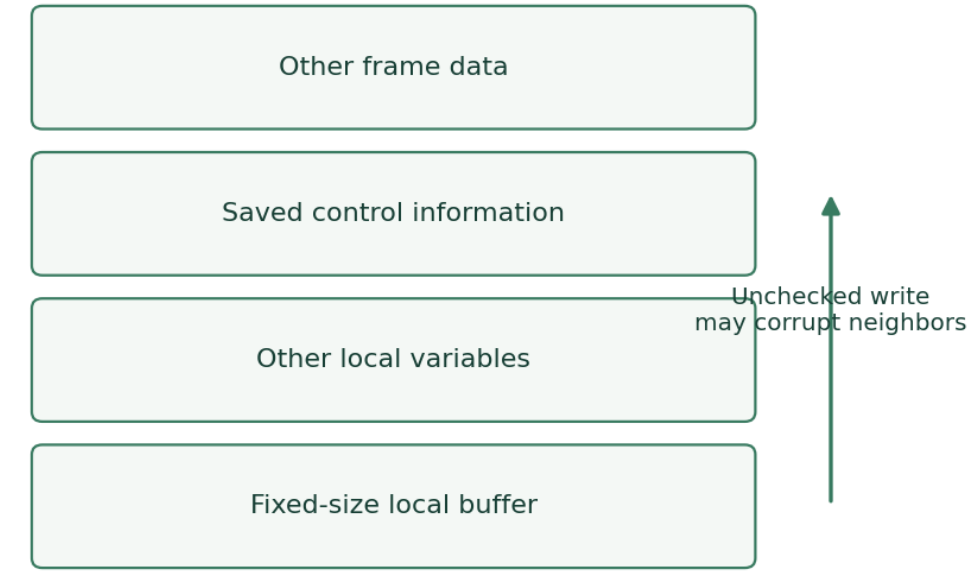
2(d) | Buffer overflow and conceptual stack layout

A buffer overflow occurs when a program writes beyond a buffer's allocated bounds. In a vulnerable stack frame, an unchecked write may corrupt adjacent local variables, control data or a saved return address. The diagram is conceptual: exact order, growth direction and protections depend on the compiler and architecture.

In an unsafe hypothetical program, copying a longer string into a smaller fixed array can overwrite neighboring bytes. If control data are corrupted, execution may crash or be redirected. The explanation is a local memory-safety mechanism, not an instruction to attack a service.

Prevent with bounds checking and safer APIs, memory-safe languages where practical, compiler stack protection, nonexecutable memory and ASLR. These defenses complement correct code; stack layout alone does not demonstrate a working exploit.

Conceptual vulnerable stack frame · layout varies by platform



Bounds checks prevent writes beyond the allocated buffer.

Revision answer: An out-of-bounds write can corrupt adjacent data or control information.

2(e) | Five malware types

Virus: attaches to a host file/program and spreads when that host runs. Worm: self-propagates between systems. Trojan: poses as useful software while hiding harmful behavior. Ransomware: denies access to data or systems and demands payment. Spyware: covertly collects information about activity or data. These categories can overlap within one malicious program.

Revision answer: Virus, worm, Trojan, ransomware and spyware.

2(f) | RSA signatures and correctness

Textbook setup: choose RSA modulus n=pq, public exponent e and private exponent d such that ed≡1 modulo phi(n), with suitable primes and gcd(e,phi)=1. Encode the message hash as representative h in the RSA domain. Sign s=h^d mod n. Verify v=s^e mod n and check it matches the correctly encoded hash of the received message.

Correctness: ed=1+k phi(n), hence s^e=h^(ed)≡h mod n; for representatives not coprime to n, the same result follows separately modulo p and q and then by CRT. In practical RSA signatures use a specified secure encoding such as RSA-PSS; raw textbook exponentiation is not a secure signature construction.

Revision answer: Sign the encoded hash with d; verify with e; RSA exponent identities recover the representative.

3(a) | Birthday paradox and hash collisions

Assume independent, uniformly distributed birthdays over 365 days and ignore leap days. For 58 people, no collision requires each new birthday to differ from all earlier ones: P(no match)=(365/365)(364/365)…(308/365). Therefore P(at least one match)=1−product(i=0..57)(1−i/365)=0.99166498, or 99.1665%. This supports the paper's approximately 99% statement; it is not exactly 99%.

For an ideal hash with N equally likely outputs and q independent distinct-message hashes, P(collision)=1−product(i=0..q−1)(1−i/N). When q is small relative to N, this is approximately 1−exp(−q(q−1)/(2N)). About 50% collision probability occurs near q≈sqrt(2N ln 2)=1.1774 sqrt(N). Thus an n-bit hash has generic collision-search scale 2^(n/2), rather than 2^n. Real nonuniform birthday patterns and nonideal hash functions need separate analysis.

Revision answer: 58 uniform birthdays give about 99.12% match probability; generic n-bit hash collisions take order 2^(n/2) trials.

3(b) | AES ShiftRows, MixColumns and AddRoundKey

The input is already after SubBytes. Use the standard AES column-major loading: state[r,c]=input[4c+r]. All displayed bytes are hexadecimal.

Initial state rows:

[10 0e 2e 0d]

[07 23 01 0f]

[1a 17 02 1a]

[13 03 17 09]

1. ShiftRows rotates rows 0,1,2,3 left by 0,1,2,3 bytes respectively:

[10 0e 2e 0d]

[23 01 0f 07]

[02 1a 1a 17]

[09 13 03 17]

2. MixColumns multiplies each column by the GF(2^8) matrix with rows [02 03 01 01], [01 02 03 01], [01 01 02 03], [03 01 01 02]. Addition is XOR; multiply by 02 means xtime modulo x^8+x^4+x^3+x+1; 03·v=(02·v) xor v.

For the first output byte: 02·10 xor 03·23 xor 02 xor 09 = 20 xor 65 xor 02 xor 09 = 4e. Repeat for every row of every column. Mixed state:

[4e 16 54 13]

[59 31 1d 2d]

[2c 0e 10 1d]

[03 2f 61 29]

3. AddRoundKey XORs each byte with 01. Resulting state:

[4f 17 55 12]

[58 30 1c 2c]

[2d 0f 11 1c]

[02 2e 60 28]

Serialized in standard column-major order: 4f 58 2d 02 17 30 0f 2e 55 1c 11 60 12 2c 1c 28.

Layout note: if your instructor intends the list to be written row-by-row instead of the AES standard, the alternate final state is:

[4f 2c 11 2e]

[58 1c 60 17]

[2d 28 55 30]

[02 12 1c 0f]

The paper does not explicitly define loading order, so the standard is the main answer and the alternative is disclosed. This is the output of these specified round operations, not a full AES encryption from plaintext.

Revision answer: Standard AES column-major final bytes: 4f 58 2d 02 17 30 0f 2e 55 1c 11 60 12 2c 1c 28.

3(c) | ElGamal public key, encryption and decryption

Given p=59, generator g=2, Bob's private exponent x=25 and message M=8. Compute y=g^x mod p=2^25 mod59=11. Public parameters are (p,g,y)=(59,2,11); if the question calls it a public-key pair, (g,y) is the pair with modulus p understood.

With ephemeral k=4: c1=g^k modp=2^4 mod59=16; shared key s=y^k modp=11^4 mod59=9; c2=M·s modp=8×9 mod59=13. Ciphertext=(c1,c2)=(16,13).

Bob computes s′=c1^x modp=16^25 mod59=9. Its inverse modulo59 is 46, since 9×46≡1. Recover M=c2×(s′)^−1 mod59=13×46 mod59=8.

Correctness: y^k=(g^x)^k=(g^k)^x=c1^x, so multiplying by the inverse cancels the mask. These tiny numbers are for the exercise only.

Revision answer: Public (59,2,11); ciphertext (16,13); decryption recovers 8.

4(a) | Authentication versus authorization

Authentication checks who a claimant is, for example by verifying a password plus a second factor. Authorization checks what an authenticated principal may do, such as allowing a teacher to update their own course but not another teacher's records. A valid login does not imply permission to every resource.

Revision answer: Authentication verifies identity; authorization decides permitted actions.

4(b) | Six evidence sources for forensics

1. Storage files and filesystem metadata. 2. Volatile memory and running-process state. 3. Operating-system and security logs. 4. Network captures and network-device logs. 5. Application artifacts such as browser history or email. 6. Mobile/cloud records such as provider audit logs and backups. Acquire lawfully, preserve integrity and record source, time and chain of custody; volatile evidence may disappear on shutdown.

Revision answer: Disk, memory, OS logs, network data, application artifacts and mobile/cloud records.

4(c) | Salted-password search space

A 2-byte salt has 2^16=65,536 possible values. A dictionary of 1,000,000 candidate words combined with every possible salt gives 1,000,000×65,536=65,536,000,000 word-salt combinations. This is the all-salt precomputation space under the question's apparent interpretation.

Important distinction: a normal stored salt is public. For one chosen account with its salt already known, the attacker needs only the 1,000,000 dictionary guesses, each hashed using that known salt. Salting prevents reusable precomputation across salts; it does not add secret-password entropy.

Revision answer: All-salt space: 65,536,000,000 combinations; one known-salt account: 1,000,000 guesses.

4(d) | Polymorphic versus metamorphic virus

Polymorphic malware changes its encoded/encrypted representation and often its decryptor between copies while retaining the underlying payload logic. Metamorphic malware rewrites its own code into functionally equivalent forms, for example changing instructions or rearranging independent blocks, without relying merely on an encrypted wrapper. Both aim to frustrate simple byte-signature detection; behavior and structural analysis remain useful.

Revision answer: Polymorphic changes representation/wrapper; metamorphic rewrites equivalent code.

4(e) | Interpret drwxr----x

Read as d | rwx | r-- | --x. It is a directory. Owner: read, write and execute. Group: read only. Others: execute/search only. Octal permissions are 741. For a directory, read lists names, execute permits traversal/search and write permits modifying entries, usually requiring execute as well. Group members without execute cannot normally access entries by name through that directory.

Revision answer: Directory; owner rwx, group r--, others --x; mode 741.

4(f) | Rule-based versus statistical IDS

Rule/signature-based IDS matches observed events to explicit known patterns or rules. It is explainable and effective for covered behaviors but may miss novel variants or poorly specified cases. Statistical/anomaly IDS models expected behavior and flags deviations; it can expose unfamiliar activity but may produce false alarms when legitimate behavior changes. Rules can also express policy violations, and anomaly detection is not automatically proof of an intrusion.

Revision answer: Rules detect specified patterns; statistical models detect departures from a baseline.

4(g) | Two DHCP-based attacks

DHCP starvation exhausts the available address pool using many requests, disrupting legitimate client configuration. A rogue DHCP server supplies unauthorized network settings, potentially redirecting clients through a malicious gateway or resolver. Defend with DHCP snooping/trusted server ports, appropriate rate limits, port controls and monitoring.

Revision answer: Address-pool starvation and rogue DHCP responses.

4(h) | HTTP GET versus POST

GET requests retrieval of a resource representation and is defined to be safe and idempotent; query parameters commonly appear in the URL. POST asks the resource to process submitted content, commonly in the request body, and is not generally idempotent. POST is not automatically confidential: use HTTPS for both. Avoid placing secrets in URLs because they can appear in history and logs, and use CSRF protection for relevant state-changing browser requests.

Revision answer: GET retrieves; POST submits for processing. Both require HTTPS for confidentiality.

5(a) | Digital signature and its properties

A digital signature is generated with a private signing key and checked using its corresponding public verification key. It binds a message to the key holder under the scheme's assumptions. Desired properties include message integrity, origin authentication, public verifiability and resistance to forgery; changing the message should invalidate the signature. It can support nonrepudiation when identity, key custody, timestamps and evidence are managed appropriately. It does not itself encrypt or hide the message.

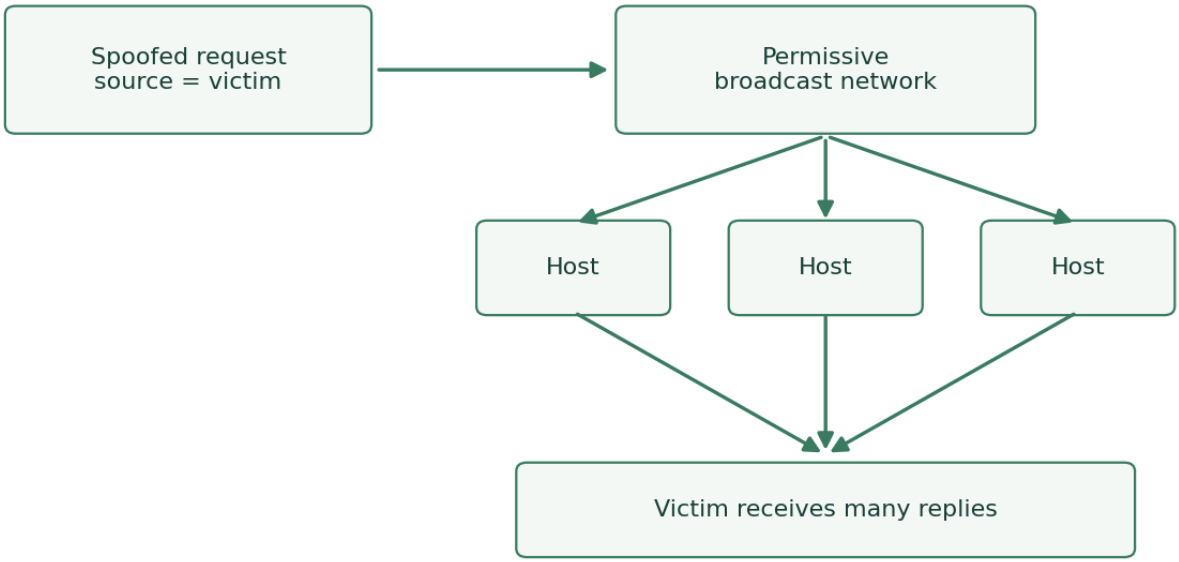
Revision answer: Private-key signing and public verification support authenticity and integrity.

5(b) | Smurf reflection/amplification mechanism

Conceptually, a spoofed ICMP echo request appears to originate from a victim and is sent to a network that permits directed-broadcast replies. Multiple hosts reply to the victim, producing reflection and possible amplification. The diagram shows the mechanism rather than an operational attack procedure.

Defend by disabling IP-directed broadcasts, blocking inappropriate broadcast echo responses, filtering spoofed source addresses and monitoring/rate-limiting abusive traffic. Reflection depends on vulnerable network behavior; it is not a feature every modern network permits.

Smurf · conceptual reflection / amplification



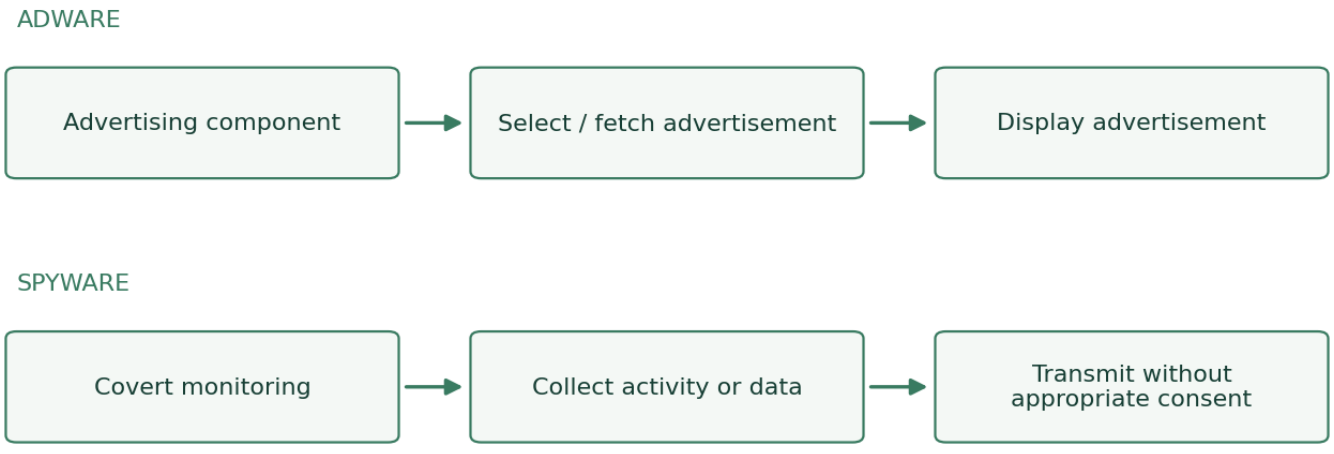
Revision answer: Spoofed victim source + broadcast request → many reflected replies to the victim.

5(c) | Adware and spyware with flow diagrams

Adware displays advertising and may be bundled with other software; its behavior ranges from consented advertising support to unwanted or deceptive conduct. Spyware covertly monitors and collects activity or sensitive data without appropriate consent. The two can overlap when advertising software secretly tracks people.

The diagram contrasts advertising display with covert collection/transmission. Reduce risk through trusted installation sources, meaningful consent, restricted permissions, endpoint protection and removal of unwanted applications.

Adware and spyware · distinct behaviors can overlap



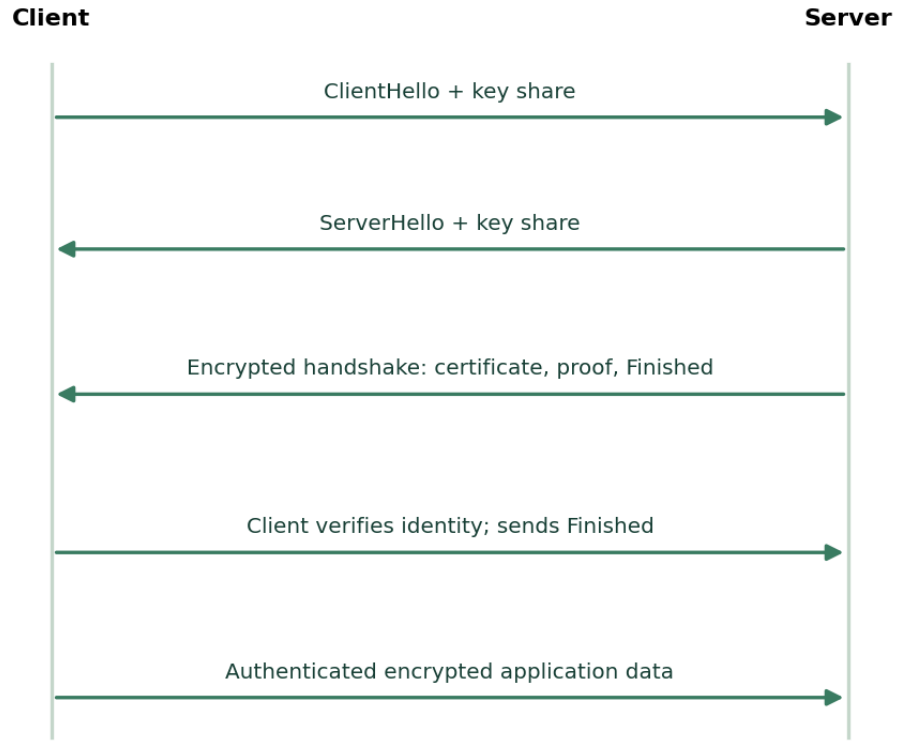
Revision answer: Adware serves advertising; spyware covertly collects information.

5(d) | Establishing a client-server SSL/TLS connection

The question uses SSL terminology; obsolete SSL is not appropriate for deployment. A conceptual modern TLS 1.3 handshake is: client sends ClientHello with supported parameters and key share; server selects parameters and returns ServerHello/key share; the server supplies its certificate and proof of key possession plus Finished; the client validates identity and handshake, then sends Finished. Shared secrets are derived into separate traffic keys, and application data uses authenticated symmetric encryption.

The certificate's hostname, trust chain and validity must be checked. Optional client authentication adds client credentials. Older textbook TLS/SSL handshakes can use different message ordering and RSA key transport; do not mix those with this TLS 1.3 diagram.

Conceptual TLS 1.3 handshake (ordinary full handshake)



Revision answer: Negotiate, authenticate server, derive keys and exchange encrypted authenticated data.

5(e) | Static versus dynamic analysis

Static analysis examines a suspicious file without running it: inspect hashes, strings, metadata, imports and code structure. It is safer to begin with but obfuscation can hide behavior. Dynamic analysis runs the file in a controlled isolated environment and observes process, filesystem, registry and network behavior. It can reveal runtime actions but may miss delayed or environment-aware behavior. Use snapshots, restricted networking and an appropriately isolated lab; never run an unknown file on a working machine merely to inspect it.

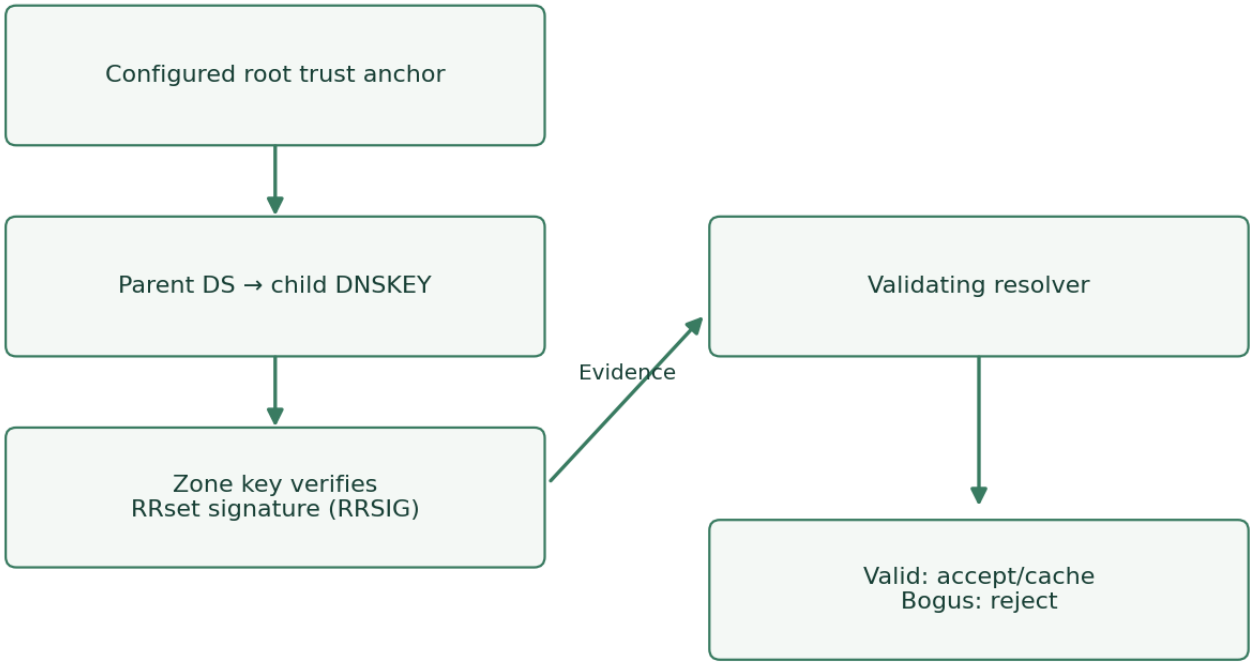
Revision answer: Static inspects without execution; dynamic observes behavior during isolated execution.

5(f) | How DNSSEC counters cache poisoning

A signed zone publishes signatures over record sets. A validating resolver checks the record signature using the zone DNSKEY and validates the delegation chain through DS/DNSKEY relationships to a configured trust anchor. A forged record cannot normally produce a valid signature, so a bogus signed answer is rejected rather than accepted into cache.

The diagram shows the chain of trust and the validation decision. DNSSEC supplies data-origin authentication and integrity, including authenticated denial for properly signed negative answers; it does not encrypt DNS traffic or guarantee that an unsigned domain is secure. It also does not fix a compromised legitimate signing key or malicious authorized zone content.

DNSSEC · chain of trust and validation



Revision answer: Validate signed DNS data through a trust chain; reject bogus signatures.

6(a) | RSA: private key, ciphertext and decryption

Given p=11, q=3, e=7. n=pq=33; phi(n)=(11−1)(3−1)=20. Find d with 7d≡1 mod20: d=3 because 7×3=21=1+20. Public key (e,n)=(7,33); private exponent d=3.

Message M=31≡−2 mod33. Cipher C=31^7 mod33=(−2)^7 mod33=−128 mod33=4. Decrypt M′=C^d modn=4^3 mod33=64 mod33=31, matching M.

Handwritten calculations on the photograph are not an answer key; the modular powers are computed from the printed data. Tiny textbook RSA is for arithmetic practice and lacks the padding and sizes of a secure implementation.

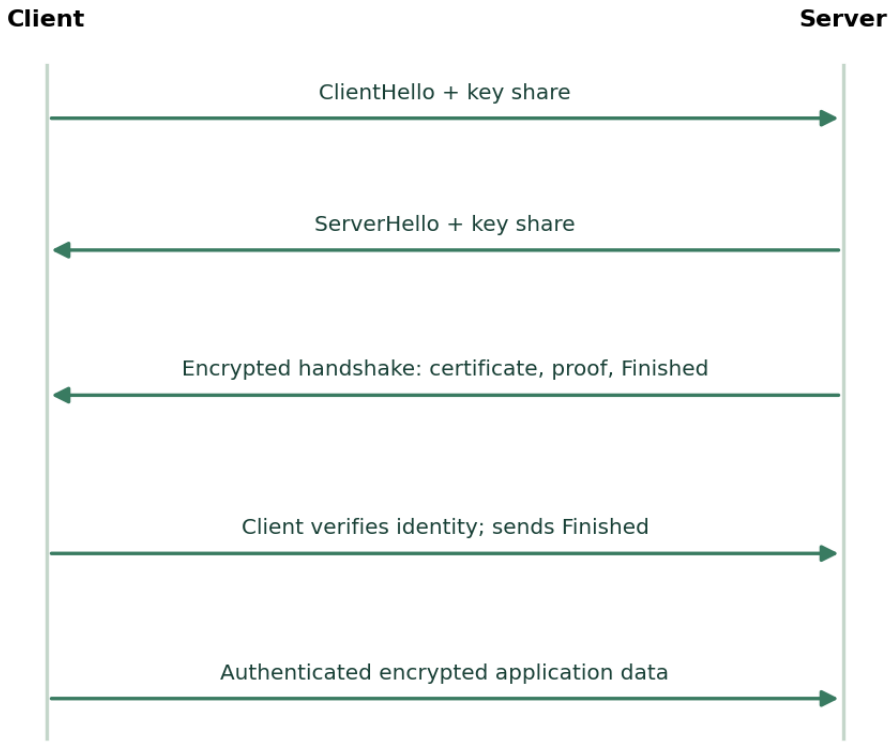
Revision answer: d=3, n=33, C=4; decrypted message=31.

6(b)(i) | HTTPS/TLS session for data transfer

HTTPS carries HTTP inside an authenticated encrypted TLS channel. Resolve and connect to the intended hostname, negotiate TLS, validate the server's certificate and handshake proof, derive session traffic keys, and then exchange HTTP requests/responses protected by authenticated encryption. The server typically proves possession of a private authentication key; bulk data uses symmetric session keys.

The TLS diagram illustrates version 1.3. HTTPS protects the connection to the validated hostname; it does not guarantee that a site's content or business is honest, nor protect data after a compromised endpoint decrypts it.

Conceptual TLS 1.3 handshake (ordinary full handshake)



Revision answer: HTTP over a validated TLS connection uses symmetric authenticated encryption for data.

6(b)(ii) | Session hijacking and mitigations

An attacker impersonates a logged-in user by obtaining or fixing an authenticated session identifier. Possible causes include exposed cookies, XSS, insecure transport, predictable tokens or failure to rotate an identifier after login.

Use HTTPS throughout; high-entropy tokens; Secure, HttpOnly and appropriate SameSite cookies; rotation after authentication/privilege changes; idle and absolute expiry; server-side invalidation on logout; XSS prevention and reauthentication for sensitive actions. CSRF protection prevents a different class of unauthorized action and remains useful, but is not a substitute for protecting session tokens.

Revision answer: Protect, rotate, expire and revoke unpredictable session identifiers.

6(c)(i) | URL obfuscation example

URL obfuscation makes a destination look like a trusted site through misleading text, lookalike hostnames, encoding or user-info syntax. Safe illustrative example: https://trusted.example@evil.example/login has hostname evil.example; trusted.example is user-info before @. Another example is trusted.example.evil.example, which is under evil.example, not trusted.example. All example domains are reserved for documentation.

Inspect the actual parsed hostname, use trusted bookmarks and password-manager origin matching, and avoid relying on link display text alone. HTTPS to the wrong hostname still encrypts a connection to that wrong hostname.

Revision answer: Misleading URL text hides the actual destination; inspect the true hostname.

6(c)(ii) | SQL injection and prevention

SQL injection occurs when untrusted input is concatenated into SQL and changes its structure. In a toy login query built as SELECT * FROM users WHERE name='<input>', an input containing a quote and SQL syntax can change the predicate rather than remain a name value. This illustrates the flaw without targeting a service.

Use a parameterized query such as SELECT * FROM users WHERE name=? and bind the value separately. The database then treats the value as data, not executable SQL. Use allowlists for identifiers that cannot be parameters, least-privilege database accounts and safe error handling. Store passwords with an appropriate password hash and verify them correctly; query safety does not replace password security.

Revision answer: Separate SQL code from values with bound parameters; never concatenate untrusted input.

Reference reading

William Stallings, Cryptography and Network Security: Principles and Practice.

NIST SP 800-38A: https://csrc.nist.gov/pubs/sp/800/38/a/final

NIST SP 800-63B: https://pages.nist.gov/800-63-4/sp800-63b.html

AES FIPS 197: https://csrc.nist.gov/pubs/fips/197/final

NIST forensic guide: https://csrc.nist.gov/pubs/sp/800/86/final

DNSSEC RFC 4033: https://www.rfc-editor.org/rfc/rfc4033

These are supporting reading references, not claims that this paper or its answer key appears in those books. Course-specific terminology and source ambiguities are noted beside the affected answers.

Shahjalal University of Science & Technology
Department of Computer Science and Engineering
4th Year 1st Semester Final Examination 2023
Course: CSE 461 (Introduction to Computer Security and Forensics)
Credits: 3 Marks: 100 Time: 3 Hours

Group A
(Answer ALL the questions)

1. **Answer any FIVE** **5x2=10**
   a) What do you understand by confidentiality? Mention four tools used to achieve it.
   b) What do you mean by biometric? Mention four candidates for biometric IDs.
   c) Which attack could be posed on One Time Pads encryption method?
   d) What are the steps of worm/malware development?
   e) "Choosing switch over hub is a good decision from a security aspect"- do you agree? Why or why not?
   f) How ARP spoofing can be prevented? Give two reasons at least.
   g) N users in a centralized network will communicate **only** with the server using symmetric key encryption. How many different keys are needed?
   h) Differentiate between second image resistance and collision resistance in Cryptographic Hash function.

2. **Answer any FOUR** **4x5=20**
   a) Discuss ten security principles in brief.
   b) Explain Shannon's confusion and diffusion properties. Also identify correct association of AES methods with them.
   c) What is Computer Forensics? Describe Forensic Paradigm.
   d) What is buffer overflow? How can you conduct buffer overflow attack? Explain with stack layouts.
   e) Discuss five different types of malwares in brief.
   f) In RSA signature, write down the signature and verification steps and provide the correctness of verification.

2x10=20

c) What is Computer Forensics? Describe Forensic Paradigm.

d) What is buffer overflow? How can you conduct buffer overflow attack? Explain with stack layouts.

e) Discuss five different types of malwares in brief.

f) In RSA signature, write down the signature and verification steps and provide the correctness of verification.

3 **Answer any TWO** **2x10=20**

a) "If approximately 58 people are present in a room, there is 99% chance that at least two of them has same birthday"- prove this birthday paradox statement in the context of collision of hash values of different messages. **10**

b) Assume that the following text block for AES encryption after the SubBytes step (contains only hexadecimal values; each bigram represents 1 byte of text) **2+5+3**

{10, 07,1a,13,0e,23,17,03,2e,01,02,17,0d,0f,1a,09}

you may assume the first row of mix const matrix [02, 03, 01, 01]

and the round key is given as

{01,01,01,01,01,01,01,01,01,01,01,01,01,01,01,01}

i. Apply Shift Row step
ii. Apply Mix Column step
iii. Apply Add Round Key step
- to find the encrypted block

c) Suppose Alice wants to send a message M = 8 to Bob using the Elgamal cryptosystem. Bob has a prime number p = 59, and a primitive root in Z_p, g = 2, and x = 25. **1+4+5**

i. What is the public key pair that Alice will use to encrypt the message M?
ii. Show the result of encryption using the public key when k = 4.
iii. Now, Bob wants to decrypt the message sent by Alice using his private key x. Show the correctness of the decryption process.

Group B

(Answer ALL the questions)

4. **Answer any FIVE** **5x2=10**

a) Differentiate between authorization and authentication.
b) Mention six possible evidence's sources of forensic analysis.
c) Calculate the search space if a system used 2-byte salt and the attacker had a 1 million-word dictionary for attacking salted passwords?
d) Differentiate between polymorphic virus and metamorphic virus.
e) What is meant by the 10-character access control notation **drwxr- - - -x**?
f) Differentiate between rule based and statistical intrusion detection system.
g) Mention two different attacks based on DHCP in brief.
h) Differentiate between HTTP GET and POST request.

5. **Answer any FOUR** **4x5=20**

a) What is digital signature? Write down its properties.
b) How "Smurf attack" is implemented? Explain with necessary figure/flow diagram.
c) Define adware and spyware with necessary flow diagram.
d) How is SSH connection established between a client and a server?
e) Differentiate between Static and Dynamic Analysis of a suspicious file in a system.
f) How does DNSSEC prevent DNS cache poisoning? Explain with a figure.

6. **Answer any TWO** **2x10=20**

a) In RSA, two prime numbers are picked, p = 11, q = 3, and e = 7. **6+2+2**
   i. Find the private key d.
   ii. If message M = 31. Find the cipher C.
   iii. Find the decipher text after decryption and compare it with plaintext.
b) i. Explain how **HTTPS/TLS** protocol works to establish a session to transfer data with proper diagrams. **5+5**
   ii. How session hijacking attack can be imposed? What measures can be taken to mitigate this attack? – answer briefly.
c) i. Describe URL obfuscation attack with example. **5+5**
   ii. Describe SQL injection attack with example.

$4^2\ 3^{3^3} \bmod 7$ $\quad 31^{33} \bmod 7$ $\quad 4^3 \times 4^3 \times 4^3 \times 4^3 \times 4^3 \times 4^3 \times 4^3 \times 4^3$

$n = p * q = 33$ $\quad (e, n) = (7, 33)$ $\quad C = 6$

$\phi(n) = (p-1) * (q-1) = 20$ $\quad C = p^e \bmod n$

$p = c^d \bmod n$

$(4^{16} \times 4^4 \times 4^2 \times 4) \bmod 33$ $\quad d = e^{-1} \bmod \phi(n)$

$\phi(n)\, d \neq +1$